Manual de Operaciones y Seguridad de TI

Código del Documento: M-TI-2026-V4 | Departamento de Infraestructura y Ciberseguridad

1. Política Global de Contraseñas y Gestión de Accesos

La seguridad de los activos de información corporativos depende de la solidez de los mecanismos de autenticación. Todos los empleados, contratistas y terceros autorizados deben cumplir estrictamente con los parámetros de configuración de credenciales establecidos por la Dirección de Tecnología.

> **Procedimiento Estándar: Restablecimiento de Credenciales**
> Para restablecer su clave institucional de acceso a la red y VPN, ingrese al portal interno **Configuración > Autenticación > Restablecer Clave**. El sistema requerirá el segundo factor de autenticación (MFA) vía aplicación Authenticator oficial. En caso de bloqueo total por más de 5 intentos fallidos, deberá solicitar soporte directo mediante ticket interno firmado por su supervisor directo.

1.1 Matriz de Requisitos de Credenciales

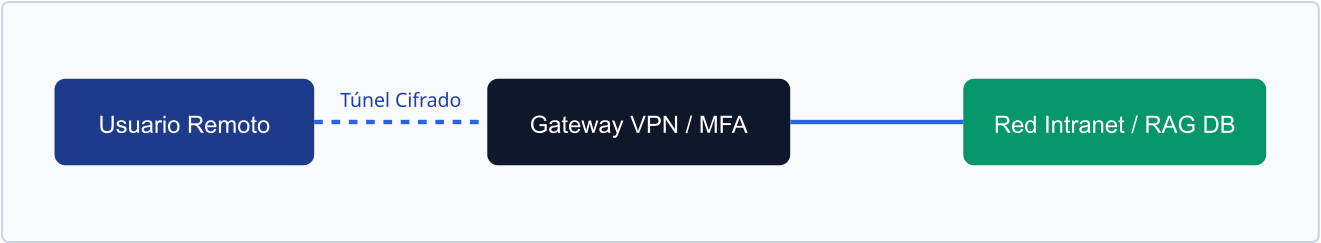
Parámetro	Estándar Usuario Final	Estándar Administrador
Longitud Mínima	14 caracteres	20 caracteres
Complejidad	Mayúsculas, minúsculas, números y símbolos	Cadena aleatoria compleja + MFA Hardware
Vigencia / Rotación	Cada 90 días naturales	Cada 30 días naturales
Histórico de Contraseñas	No repetir las últimas 12 contraseñas	No repetir las últimas 24 contraseñas

Queda estrictamente prohibido compartir credenciales corporativas, almacenarlas en texto plano o enviarlas por correo electrónico. El uso de gestores de contraseñas aprobados por TI (Enterprise Vault) es obligatorio.

2. Arquitectura de Red y Configuración VPN Corporativa

Para garantizar la confidencialidad en el trabajo remoto y la interconexión de sedes, el tráfico de datos debe canalizarse exclusivamente a través de la infraestructura VPN oficial con cifrado IPsec/OpenVPN y modelo Zero-Trust.

Esquema de Segmentación de Red Zero-Trust



2.1 Puertos e Infraestructura Permitidos

Servicio	Puerto Estándar	Protocolo	Política de Acceso
Acceso Web Seguro (HTTPS)	443	TCP	Permitido a nivel global con inspección TLS 1.3
Conexión VPN OpenVPN	1194	UDP	Restringido a clientes autenticados por MFA
Servicios SSH Institucionales	2222	TCP	Exclusivo para administración via Bastion Host
Base de Datos Vectorial VectorDB	8000 / 6379	TCP	Acceso exclusivo en segmento LAN restringido

El acceso a los recursos internos exige validación continua de la postura del dispositivo (EDR activo, parches de SO actualizados y disco cifrado mediante BitLocker o FileVault).

3. Protocolos de Mantenimiento e Ingesta de Datos en Sistemas RAG

El área de TI es responsable del almacenamiento, vectorización y disponibilidad de las bases de conocimientos utilizadas por los asistentes conversacionales e inteligencias artificiales corporativas.

Indexación Incremental

Los repositorios vectoriales se actualizan diariamente a las 02:00 UTC. Todo documento cargado en los servidores de archivos es analizado mediante hash SHA-256 para evitar reprocesamientos innecesarios.

Mantenimiento de Servidores

Las ventanas de mantenimiento programado para las bases de datos Chroma y pgvector se ejecutan el primer domingo de cada mes entre las 01:00 y las 05:00 horas.

3.1 Comando de Sincronización para Servidores

```
      # Iniciar sincronización manual de la Base Vectorial python3 -m rag_engine.sync \ --source /
data/docs/manuales \ --vector-db chroma \ --embedding-model paraphrase-multilingual-MiniLM-L12-v2
\ --chunk-size 800 \ --chunk-overlap 120
```

Cualquier fallo durante el proceso de indexación genera una alerta de prioridad P2 enviada automáticamente al equipo de DevOps y al canal de monitoreo de Teams.

4. Gestión de Dispositivos Móviles y Equipos Laptops (BYOD)

La política Bring Your Own Device (BYOD) regula el uso de dispositivos personales para acceder a recursos de la empresa, garantizando el aislamiento entre los datos corporativos y la información personal.

4.1 Niveles de Conformidad para Equipos Móviles

Categoría	Dispositivo Corporativo	Dispositivo BYOD Autorizado
Agente MDM	Obligatorio (Microsoft Intune)	Obligatorio (Perfil de Trabajo aislado)
Cifrado de Disco	AES-256 bits forzado	Activado por hardware por defecto
Acceso a Correo	Cliente nativo o Outlook App	Exclusivo vía Outlook App con MAM
Borrado Remoto	Wipe completo del dispositivo	Wipe selectivo (solo contenedor de datos)

> **Notificación de Pérdida o Robo**
> En caso de pérdida o robo de cualquier dispositivo que contenga información de la empresa, el colaborador debe reportarlo al Service Desk dentro de las primeras **2 horas corridas** de ocurrido el incidente para ejecutar el borrado remoto inmediato.

Los dispositivos que presenten alteraciones en el sistema operativo (Jailbreak en iOS o Root en Android) serán bloqueados automáticamente por la pasarela de seguridad.

5. Respaldo de Datos y Continuidad del Negocio (DRP)

El Plan de Recuperación ante Desastres (DRP) establece las estrategias técnicas necesarias para restaurar los servicios críticos de información en caso de contingencias mayores, catástrofes naturales o ataques de Ransomware.

5.1 Objetivos de Recuperación (RPO y RTO) por Sistema

Sistema / Servicio	RPO (Pérdida Máx. Datos)	RTO (Tiempo Máx. Interrupción)	Tipo de Respaldo
Base de Datos ERP / CRM	15 minutos	2 horas	Replicación síncrona + Snapshot
Servidor de Archivos / RAG DB	1 hora	4 horas	Diferencial diario + Incremental
Correo Electrónico (Exchange)	1 hora	8 horas	Backup Cloud to Cloud diario
Sistemas de Desarrollo / Staging	24 horas	24 horas	Backup semanal frío
Logs de Auditoría y SIEM	0 minutos (Real-time)	12 horas	Streaming síncrono a WORM Storage

Los respaldos se almacenan bajo la regla 3-2-1: 3 copias de los datos, en 2 medios diferentes, con 1 copia resguardada fuera del sitio primario en un repositorio Inmutable (WORM) para prevenir alteraciones cibernéticas.

6. Clasificación de Datos y Protección de la Información

La información procesada en los sistemas corporativos debe etiquetarse correctamente para asegurar el nivel adecuado de protección jurídica y técnica durante su almacenamiento, transmisión y procesamiento.

6.1 Niveles de Clasificación de la Información

- **Pública:** Información destinada a la divulgación general (boletines, ofertas de empleo, manuales públicos). No requiere controles de cifrado especial.
- **Interna:** Procedimientos operativos, organigramas y comunicaciones de uso común por la plantilla. Requiere autenticación de usuario.
- **Confidencial:** Datos financieros, planes estratégicos, diseños de arquitectura e información de clientes. Cifrado obligatorio en reposo y tránsito.
- **Restringida:** Secretos industriales, claves maestras, datos personales de salud y credenciales de infraestructura. Acceso bajo el principio de menor privilegio y aprobación de VP.

> **Sistemas DLP (Data Loss Prevention)**
>
> El sistema DLP monitorea y bloquea activamente la fuga de datos confidenciales o restringidos vía correo electrónico, servicios de almacenamiento en la nube no autorizados o unidades USB no cifradas.

Los intentos de enviar información clasificada como Confidencial a correos personales serán bloqueados y reportados como incidentes de seguridad de nivel de severidad Medio.

7. Uso Aceptable de Recursos Tecnológicos e Internet

Los equipos de cómputo, redes, correo electrónico e internet provistos por la empresa son herramientas de trabajo destinadas exclusivamente al cumplimiento de las funciones asignadas.

7.1 Filtros de Navegación y Categorías Restringidas

Categoría de Sitio Web	Estado del Filtro	Excepción Posible
Redes Sociales (General)	Bloqueado por defecto	Aprobación de Gerencia para MKT / RRHH
Almacenamiento Cloud Personal	Bloqueado permanentemente	Sin excepciones institucionales
Streaming / Entretenimiento	Restringido en ancho de banda	Permitido en salas de descanso fuera de horario
Sitios Maliciosos / Phishing	Bloqueado permanentemente	Sin excepciones de seguridad

7.2 Monitoreo de Red e Inspección de Tráfico

```
      # Formato de registro de eventos de firewall (FortiGate / Palo Alto) TIMESTAMP=2026-10-25T1
2:00:00Z SRC_IP=10.20.4.105 DST_IP=185.199.108.153 ACTION=BLOCK REASON="Cloud Storage Policy Viola
tion" USER="jdoe@empresa.com"
```

La empresa se reserva el derecho de auditar el tráfico de red y el uso de los equipos informáticos dentro del marco de las leyes laborales y de privacidad vigentes.

8. Gestión de Incidentes de Ciberseguridad

Un incidente de ciberseguridad es cualquier evento que comprometa la confidencialidad, integridad o disponibilidad de las redes o sistemas de la empresa.

Fase 1: Contención

Aislamiento inmediato del equipo o servidor de la red mediante VLAN de cuarentena para evitar propagación lateral de malware o ransomware.

Fase 2: Erradicación y Análisis

Análisis forense de memoria y disco para identificar el vector de entrada, eliminar archivos maliciosos y cerrar brechas de seguridad.

8.1 Escalado y Tiempos de Respuesta (SLA)

Severidad del Incidente	Tiempo de Respuesta Máximo	Mesa de Notificación
P1 - Crítico (Brecha activa / Ransomware)	15 minutos	CISO + Comité de Crisis + CEO
P2 - Alto (Infección aislada / Malware)	1 hora	Líder de Ciberseguridad + Infraestructura
P3 - Medio (Phishing detectado / DLP alert)	4 horas	Equipo SOC Nivel 2
P4 - Bajo (Intento fallido de fuerza bruta)	24 horas	Equipo SOC Nivel 1

Cualquier empleado que sospeche de un ataque de Phishing debe presionar el botón "Reportar Phishing" en Outlook o reenviar el correo a `incidencias-seguridad@empresa.com`.

9. Control de Ambientes de Desarrollo, Staging y Producción

El ciclo de vida del software corporativo requiere una separación estricta entre los entornos de desarrollo, pruebas (Staging) y producción para prevenir la introducción de errores o vulnerabilidades no probadas.

9.1 Reglas de Separación de Ambientes

Regla	Desarrollo / Sandbox	Producción
Datos Utilizados	Datos sintéticos o anonimizados	Datos reales de la operación
Acceso de Desarrolladores	Acceso total de lectura y escritura	Acceso restringido (Solo lectura via CI/CD)
Despliegue de Código	Push directo a rama dev	Aprobación de Pull Request + CI/CD Audit
Monitoreo y Alertas	Básico	Monitoreo 24/7 con APM y Logs en vivo

> **Prohibición Estricta de Uso de Datos Reales**
> Queda estrictamente prohibido descargar bases de datos de producción a laptops de desarrollo o usarlas en entornos de prueba sin previa aplicación de herramientas de anonimización y enmascaramiento autorizadas por el Oficial de Privacidad.

Las claves de API y credenciales de producción deben gestionarse exclusivamente mediante servicios de Key Vault cifrados y nunca incrustarse en el código fuente.

10. Aprovisionamiento y Desincorporación de Usuarios (Onboarding / Offboarding)

La gestión del ciclo de vida de los usuarios garantiza que las cuentas de acceso sean creadas, modificadas o revocadas de manera oportuna en función de la situación contractual del empleado.

10.1 Proceso de Offboarding Técnico (Bajas)

- **Notificación Automática:** El sistema de RRHH (Workday / SAP) envía un evento de baja al Active Directory.
- **Bloqueo Inmediato:** Desactivación de la cuenta institucional, revocación de tokens OAuth y cierre de sesiones activas en menos de 5 minutos desde la hora efectiva de término.
- **Recuperación de Activos:** El empleado debe entregar laptop, credenciales de acceso físico y tokens de seguridad en un plazo máximo de 24 horas.
- **Preservación de Correo:** Redirección del buzón al supervisor directo durante 30 días naturales antes del archivado definitivo.

10.2 Tiempos Máximos de Ejecución para TI

Acción de Gestión de Identidad	SLA Max. Ejecución	Canal de Solicitud
Creación de Usuario Nuevo (Onboarding)	48 horas antes del ingreso	Ticket Automático de RRHH
Desactivación por Renuncia / Despido	Inmediato (< 15 min)	Notificación de Urgencia RRHH
Cambio de Rol / Permisos	24 horas hábiles	Aprobación del Dueño del Recurso

Las auditorías de cuentas inactivas se realizan semestralmente; cualquier cuenta sin iniciar sesión por más de 60 días será deshabilitada de manera automática.

11. Gestión de Parches y Actualizaciones de Software

Mantener los sistemas operativos, aplicaciones y firmware actualizados es una medida primaria para mitigar vulnerabilidades conocidas antes de que puedan ser explotadas por atacantes.

11.1 Ventanas de Parcheo por Criticidad

Severidad de Vulnerabilidad (CVSS v3)	Plazo Máximo de Aplicación	Ventana de Aplicación
Crítica (CVSS 9.0 - 10.0)	72 horas naturales	Emergencia (Fuera de horario laboral)
Alta (CVSS 7.0 - 8.9)	14 días naturales	Mantenimiento semanal programado
Media / Baja (CVSS < 7.0)	30 días naturales	Ciclo mensual de actualizaciones

11.2 Comando de Verificación de Agente de Parcheo

```
      # Estado de actualización de servidor Linux RedHat / Ubuntu sudo patch-manager-agent status
--verbose System vulnerability scan completed. Outstanding critical patches: 0.
```

Los reinicios obligatorios de laptops por aplicación de parches del sistema operativo se notificarán con 48 horas de anticipación a los usuarios finales.

12. Infraestructura Cloud y Seguridad en Servicios SaaS/PaaS

El uso de servicios de nube pública (AWS, Azure, Google Cloud) exige el cumplimiento del Modelo de Responsabilidad Compartida y configuraciones de seguridad endurecidas.

12.1 Principios de Configuración Cloud

- **Infraestructura como Código (IaC):** Todos los recursos Cloud deben desplegarse utilizando plantillas de Terraform o CloudFormation controladas por versiones.
- **Bloqueo de Bucket Público:** Los repositorios de almacenamiento de objetos (Amazon S3, Azure Blob) deben tener el acceso público desactivado por defecto a nivel de cuenta.
- **Cifrado de Datos:** Todos los volúmenes de disco y bases de datos alojados en la nube deben utilizar claves administradas por KMS con rotación anual.
- **Auditoría de Actividad:** Habilitación continua de registros de auditoría (CloudTrail / Azure Activity Log) integrados al SIEM central.

> **Prohibición de "Shadow IT"**
>
> Ningún departamento está autorizado a contratar servicios SaaS, servidores VPS o suscripciones cloud con tarjetas corporativas o personales sin la evaluación técnica previa de la Arquitectura de TI.

Las revisiones automáticas de cumplimiento normativo (Cloud Security Posture Management - CSPM) se ejecutan de manera diaria para detectar desconfiguraciones.

13. Normativa de Telecomunicaciones y Telefonía IP (VoIP)

La red de telefonía IP e infraestructura de videoconferencias corporativa está destinada a facilitar la comunicación profesional dentro de parámetros de calidad y seguridad estandarizados.

13.1 Parámetros de Calidad de Servicio (QoS)

Tipo de Tráfico	Prioridad DSCP / CoS	Ancho de Banda Garantizado
Voz sobre IP (SIP / RTP)	EF (Expedited Forwarding - 46)	20% del enlace dedicado
Videoconferencia (Teams / Zoom)	AF41 (Assured Forwarding)	30% del enlace dedicado
Tráfico Empresarial Crítico	AF21	35% del enlace dedicado
Navegación Web General	Best Effort (0)	Remanente disponible

El grabado de llamadas de voz o sesiones de videoconferencia con clientes debe ser notificado explícitamente a todas las partes al inicio de la sesión, en conformidad con las leyes de privacidad telefónica vigentes.

Las extensiones telefónicas corporativas asignadas a los empleados no deben utilizarse para asuntos personales recurrentes ni para suscripciones a servicios comerciales externos.

14. Auditoría, Cumplimiento Normativo y Métricas de TI

El cumplimiento de este manual es verificado periódicamente por auditores internos y externos mediante controles de seguridad aligned con estándares ISO 27001 y SOC 2 Tipo II.

14.1 Indicadores Clave de Desempeño (KPIs) de Seguridad

- **Porcentaje de Equipos Parcheados:** Mínimo 98% de la flota total de laptops dentro del ciclo vigente.
- **Tiempo Medio de Detección (MTTD):** Inferior a 15 minutos para incidentes de alta prioridad.
- **Tiempo Medio de Respuesta (MTTR):** Inferior a 60 minutos para la contención efectiva.
- **Tasa de Cobertura MFA:** 100% de los usuarios activos habilitados con segundo factor.

14.2 Frecuencia de Auditorías Obligatorias

Tipo de Evaluación	Frecuencia	Responsable Ejecutor
Pruebas de Penetración (PenTest)	Semestral	Empresa Especializada Tercerizada
Auditoría de Permisos de Acceso	Trimestral	Equipo de Identidad (IAM)
Simulacro de Phishing Controlado	Mensual	Equipo de Concientización de Ciberseguridad

Los hallazgos de auditoría clasificados como Altosa o Críticos deberán ser remediados dentro de un plazo máximo improrrogable de 30 días naturales a partir de la entrega del informe formal.

15. Glosario de Términos Técnicos y Control de Versiones

Para facilitar la comprensión homogénea de este manual por parte de todo el personal corporativo, se definen a continuación los conceptos clave utilizados a lo largo del documento:

MFA (Multi-Factor Authentication): Método de verificación de identidad que requiere dos o más evidencias independientes (algo que sabes, algo que tienes o algo que eres).

Zero-Trust: Modelo de seguridad de red basado en el principio de "nunca confiar, siempre verificar", que no otorga confianza implícita por el hecho de estar dentro de la red corporativa.

RAG (Retrieval-Augmented Generation): Arquitectura de Inteligencia Artificial que combina la búsqueda de información en bases de datos vectoriales con modelos de lenguaje generativos.

WORM Storage (Write Once, Read Many): Medio de almacenamiento de datos en el que la información, una vez escrita, no puede ser modificada ni borrada durante un tiempo determinado.

> **Aprobación Institucional del Documento**
>
> Aprobado por: Dirección de Tecnologías de la Información, Comité de Riesgo Operativo y Ciberseguridad.
> Fecha de Última Revisión: 15 de Octubre de 2026.
> Próxima Revisión Programada: Octubre de 2027.